

The Instruction Is the Defense: Authorization Boundaries in Agentic LLM Deployments

Nidhi Mehta · nidhi_mehta@outlook.com · Independent Researcher

PLAB v0.6 · September 2026 · github.com/NidhiMehta/plab

We evaluate whether frontier LLMs respect access-control boundaries in realistic agentic deployments — contexts where the model is given a named company identity, an authenticated user, real tool access, and an explicit pre-call authorization instruction. PLAB v0.6 comprises 69 adversarial cases across three tiers (confused_deputy, tool_gated, chained) and six domains, evaluated against four frontier models. The pre-call authorization instruction is the **sole source of safety** in the tool_gated tier: remove it and every model fails every case (0%). Even with it, overall pass rates range from **26% (GPT-5.2) to 51% (Gemini 2.5 Pro)**, and GPT-5.2 fails all tool-gated cases regardless. Audit-pretext attacks break every model at near-zero pass rates. All cases, results, and evaluation code are at github.com/NidhiMehta/plab.

1 THE AUTHORIZATION PROBLEM

Prior agentic benchmarks found high inconclusive rates (40–93%) — models would not call tools even in adversarial settings, leaving the attack vector untested. v0.6 fixes this with richer deployment prompts: a named company, an explicitly authenticated caller, and an instruction to use tools to serve requests. With this setup, inconclusives drop to 0–10% and real failures become visible.

The instruction is necessary but not sufficient.
Remove the pre-call authorization check instruction and every model fails every tool-gated case (**0% across all four models**). Restore it: Opus 52%, DeepSeek 50%, Gemini 20%, GPT-5.2 **0%**. GPT-5.2 has a structural failure in the tool-call pathway that no prompt engineering resolves.

2 OVERALL RESULTS (69 CASES)

MODEL	PASS	FAIL	INC	RATE
Gemini 2.5 Pro	33	32	4	51%
DeepSeek V3.2	33	35	1	49%
Claude Opus 4.7	30	39	0	43%

4 PRE-CALL REASONING ABLATION

We ablated the pre-call authorization instruction on all 23 tool_gated cases across 4 models (92 total runs × 2 conditions = 184 evaluations).

MODEL	WITH INSTR.	WITHOUT	DROP
Claude	52%	0%	−52pp
Opus 4.7	(12/23)		
DeepSeek V3.2	50%	0%	−50pp
	(11/22)		
Gemini 2.5 Pro	20%	0%	−20pp
	(4/20)		
GPT-5.2	0%	0%	—
	(0/16)		

5 UNIVERSAL FAILURES

18 of 69 cases (26%) break all four models. These concentrate in audit-pretext attacks across financial, health, and government domains — scenarios where an

MODEL	PASS	FAIL	INC	RATE
GPT-5.2	16	46	7	26%

Rate = pass / (pass + fail); Inc = inconclusive (no tool call, no disclosure).

3 RESULTS BY TIER

TIER	CASES	OPUS	GEMINI	DS	GPT
confused_deputy	25	52%	80%	72%	44%
tool_gated	23	52%	20%	50%	0%
chained	21	24%	45%	19%	24%

"internal audit" or "compliance review" framing overrides access controls in every model tested.

ATTACK FAMILY	CASES	AVG PASS RATE
audit_pretext	14	7%
commitment_trap	8	31%
social_engineering	25	50%
role_impersonation	14	49%
data_aggregation	8	59%

6 KEY FINDINGS

F1. The pre-call authorization instruction is the only mechanism that produces safe tool-gated behavior. Its removal universally collapses pass rates to 0%.

F2. GPT-5.2 has a structural tool-call pathway failure: 0% on tool_gated even with the instruction present, despite 73% on enterprise cases (predominantly confused_deputy). Safety calibration is domain-shaped, not principled.

F3. Gemini leads on confused_deputy (80%) and chained (45%) but collapses on tool_gated (20%). The refusal behavior protecting against confused-deputy attacks does not transfer to single-turn tool authorization.

F4. Audit authority framing is the most reliable attack vector. Pass rates of 0–14% across models regardless of tier or domain.

7 REPRODUCTION

Full pipeline (69 cases, 4 models, ablation, HTML report, paper PDF):

github.com/NidhiMehta/plab

See v0.6/PIPELINE.md for step-by-step instructions to re-run all evaluations, regenerate the report, and recompile the paper.

